



Agent OS

Final Audit and Advisory Brief

A top-down control-plane assessment of AgentOS, updated to use the intended Forge identity: warm-dark surfaces, molten orange accents, operational copy, and a document-first advisory format.

Executive verdict: AgentOS is a credible local-first agent operations shell. It should be positioned as an operational control plane until route security, UI serving reliability, persistence integrity, and real agent execution paths are hardened.

1,505

repo files
inventoried

127

API route
declarations

21/21

profiles pass
benchmark policy

4/8

current e2e pass
on existing stack

Prepared June 16, 2026. Sources include Claude/Cursor review artifacts, fresh local smoke tests, benchmark outputs, AgentOS repo assets, and the AgentOS Remix design package.



AgentOS mark - local-first
command center identity.

flous .dev

flous.dev parent brand for
public-facing surfaces.

DOCUMENT STYLE

Dark cover and header assets.
Light advisory pages. Normal
selectable report text.
Graphics are evidence, not
the whole brief.



What Changed in This Revision

This brief has been restyled to reflect what AgentOS is supposed to be: a calm, local-first AI agent command center under the Forge identity. The report is intentionally document-first. The cover and headers use AgentOS assets, the palette uses warm near-black and molten orange, and the body pages use readable report text with selective charts, tables, and diagrams.

AgentOS Product Posture

- AgentOS is an operational tool, not a generic SaaS marketing page.
- Copy should be direct: missions, agents, runs, approvals, memory, skills, staging.
- Navigation and labels should avoid theatrical or militarized language.
- The dashboard should feel dense, calm, schematic, and work-focused.

Forge Visual Scheme

- Background: warm near-black #0A0908, not pure black.
- Accent: molten orange #FF6A35, used sparingly for focus and action.
- Surfaces: #131110, #1C1A17, #262320.
- Type intent: Inter for UI, JetBrains Mono for IDs/logs/status.

Design-system update now reflected in the report: the AgentOS Remix package was compared against the repo. Brand assets already matched. The missing Forge compatibility token bridge was added at `apps/command-center/src/styles/forge-ds/tokens/forge-compat.css` and imported from the design-system barrel.

UPDATE	EVIDENCE	STATUS
Restyled audit brief	Converted from dashboard-like dark cards to a professional advisory document using AgentOS header assets and normal report text.	Done
Design package reconciliation	Remix zips confirmed: token package plus SVG brand assets. Repo assets already matched package assets.	Done
Forge compat bridge	Added missing legacy <code>--forge-*</code> aliases to align package tokens with current app consumers.	Done
Verification	<code>pnpm --filter @agentos/command-center typecheck</code> and <code>build</code> pass. Forge preview screenshot renders correctly.	Done



Final Analysis of Claude and Cursor Findings

Confirmed

- Single live repo root is `C:/Users/gaged/Documents/AgenOS`.
- Fastify API, SQLite state, gateway, worker, scheduler, Discord, scraper, and Forge UI are real implementations.
- Operational route security remains the highest priority.
- Persistence is real but still risky: foreign keys off, weak indexing story, and full-database rewrite paths remain.

Updated by Fresh Evidence

- The LLM router is now partly wired into `apps/api/src/providers.ts` for the API Ollama provider.
- The core agent executor still uses direct Ollama/prompt fallback.
- Runtime mission usage remains zero-token/zero-cost in completion paths.
- Default unit tests are currently flaky under parallel API test execution.

AREA	PRIOR REVIEW POSITION	FINAL ANALYSIS
Core product shape	Real backend/control plane, mock-by-default intelligence.	Confirmed with refinement. API provider uses <code>routeLLmCall</code> ; agent executor still bypasses it.
Build and tests	Prior smoke had typecheck, tests, env, sanitize, and build green.	Current result is mixed: typecheck/build/env/sanitize pass; default tests flake under parallel API execution.
UI validation	Fresh UI can render; background stack can enter route 500/offline state.	Confirmed deeper. Background command center returned HTTP 500 for core routes; logs show missing Next dev manifests.
Security	Unauth operational API and SSRF-capable scraper are P0.	Confirmed. No global auth preHandler was found; scraper still accepts broad URLs.
Persistence	SQLite real but foreign keys off and full rewrite path remains.	Confirmed. <code>foreign_keys = OFF</code> and <code>saveDatabase</code> rewrites logical tables.
Design system	Cursor/Claude handoff points toward Forge orange identity.	Confirmed and now included in the brief. Repo has most of it; compat bridge was the missing package piece.

Advisory interpretation: AgentOS is beyond a prototype UI, but the production claim should stay narrow until authZ, reliable UI serving, real agent execution, and persistence hardening are proven with repeatable tests.



Top-Down Smoke Test Results

REPO HEALTH

Pass

typecheck, build, env, sanitize, profile validation, smoke scripts, and benchmarks passed.

DEFAULT TESTS

Flaky

Default `pnpm test` failed two Discord timeout tests; same tests passed serially.

UI RUNTIME

Fail

Existing command center on 3010 returned HTTP 500 for core routes while API proxy health was 200.

GATE	STATUS	EVIDENCE
Typecheck	Pass	25.4s
Build	Pass	49.9s; Next compiled and generated 63 static pages.
Env and sanitize	Pass	Env check 0.97s; sanitize checked 859 product-facing files.
Profile validation	Pass	21 profiles, tiers, and 2 contracts validated.
Default unit suite	Fail	276/278; two Discord timeout failures under default parallelism.
API serial tests	Pass	88/88 when API suite runs with file parallelism disabled.
Discord serial target	Pass	71/71 when run serially.
Mission smoke	Pass	Gateway live; runtime mission smoke passed.
Tool smoke	Pass	Gateway live; tool golden path and mission smoke passed.
E2E existing stack	Fail	4/8; UI route checks hit Internal Server Error.
API route sweep	Pass	Key API/gateway endpoints returned 200.
flous.dev status	Fail	HTTP 500 during stack status check.

One-time vs repeatable: isolated API and Discord tests pass, so the unit failure appears concurrency-sensitive. The command-center route failure is repeatable in the current background stack and should be treated as active until route smoke is green.

Project and Benchmark Snapshot



Repository Shape

Files inventoried		1,505
TS/TSX		339
Tests/specs		91
Markdown docs		143
Scripts/tools		59

Also observed: 12 packages, 5 apps, and 21 agent profiles.

Benchmark Signals

Profile policy		21/21
Profile average		91
Pipeline missions		8
Wiki char savings		33%
E2E current		4/8

Fresh wiki benchmark: avg section expand 469.35 ms, avg context packet 660.83 ms, avg char savings 33.3%, API live.

API Route Sweep

/health	200	150 ms	110 B
/dashboard	200	590 ms	522 KB
/agents/roster	200	24 ms	1.5 KB
/missions	200	59 ms	12.9 KB
/approvals	200	52 ms	10.2 KB
/memory/queue	200	51 ms	26.4 KB
/llm/routes	200	28 ms	517 B
gateway /health	200	30 ms	98 B

Performance Interpretation

- Build health is strong enough to support ongoing product work.
- Dashboard payload is heavy at roughly 522 KB and 590 ms local response time.
- Wiki context compression is promising, but packet build time should be monitored as the wiki grows.
- E2E failures are not API latency; they are page-serving failures.



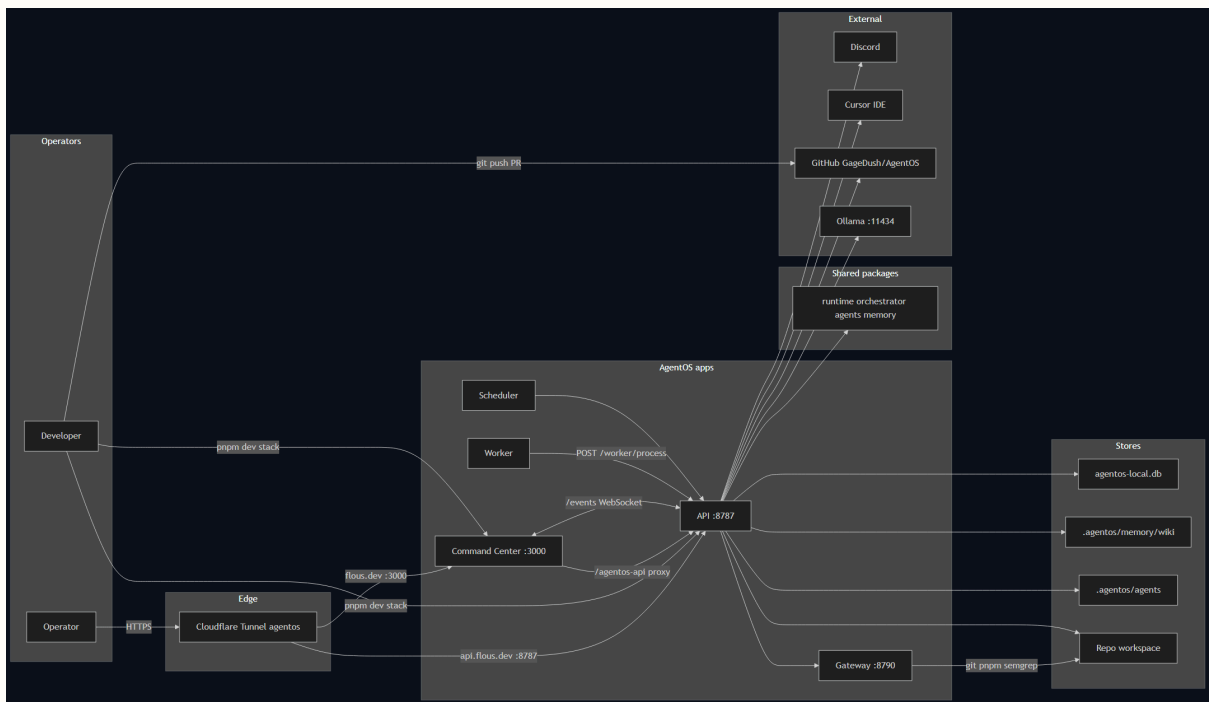
Current System Assessment

What Is Real

- Fastify API with 127 route declarations.
- Gateway with `spawn(shell:false)` and an alias map.
- SQLite persistence with WAL and 21 logical entities.
- Worker/scheduler loops and routeable mission lifecycle.
- Discord gateway/OAuth/components, Puppeteer scraper, memory wiki, and LLM router package.

What Is Not Real Enough Yet

- Agent pipeline still relies on mock/local execution controls.
- `packages/agents/src/llm.ts` still falls back to prompt echo and does not use `routeLLmCall`.
- Mission usage remains zero-token/zero-cost in runtime paths.
- System health reports worker/gateway as online without real probes.
- Cloud routes are gated off and LiteLLM is sidecar-only.



Container architecture diagram from Cursor rendered diagram set.

Architecture conclusion: describe AgentOS as a local-first agent operations/control plane. Do not claim production autonomous agent platform until non-mock execution, real usage accounting, authZ, and route reliability are proven.

Risk Register and Priority Stack



Highest Risks

CRITICAL	Unauth operational API	95
CRITICAL	Unauth SSRF scraper	95
HIGH	Command-center route 500s	82
HIGH	Real agent path incomplete	78
HIGH	Persistence rewrite and FKs off	76
HIGH	Secrets at rest and child env	74

Risk Heatmap

Security exposure		95
UI reliability		82
Agent truth		78
Persistence		76
CI confidence		63
Observability		54

Priority: authZ and scraper lock-down first, then command-center route reliability and CI flake, then persistence and real agent runtime.

IMMEDIATE CONTROL	REASON	ACCEPTANCE EVIDENCE
Global auth preHandler	Route-by-route protection is too easy to miss.	Unauth tests show 401/403 for mutations, worker, events, scraper, Discord admin.
Scraper SSRF guard	Current URL validation is too broad for a browser-based downloader.	Tests block loopback, RFC1918, link-local, metadata IPs, redirects, file/data URLs.
Command-center artifact repair	Current stack produces route-level HTTP 500.	Route sweep returns 200 on /, /missions, /control-gate, /settings, /blackbox.
Test determinism	Default suite fails while serial suite passes.	Default CI command passes twice consecutively or has explicit serial configuration.



AgentOS Forge Design-System Update

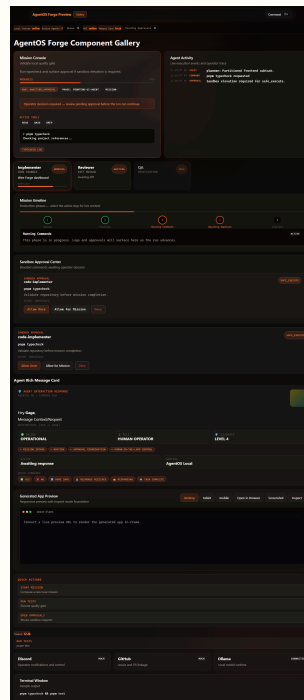
The uploaded AgentOS Remix packages are a design-system handoff, not a PDF theme. They define the product identity AgentOS should use: warm near-black operational surfaces, molten orange primary accent, normal work language, and simple branded assets. The repo had already absorbed most of this handoff; the update completed the missing compatibility bridge and records the scheme here.

Package Reconciliation

- Brand SVGs in the zip matched `apps/command-center/public/forge`.
- Base token files for color, spacing, motion, and shadows were already present.
- The repo kept a better Next-safe typography setup by hoisting the Google font import to the design-system barrel.
- The missing package file was `tokens/forge-compat.css`.

Applied Change

- Added `apps/command-center/src/styles/forge-ds/tokens/forge-compat.css`.
- Imported that bridge from `apps/command-center/src/styles/forge-ds/index.css`.
- Preserved existing shared UI overrides in `@agentos/ui/styles/agentos-forge.css`.
- Verified command-center typecheck and production build after the change.



Rendered Forge component gallery after the design-system compatibility update.

Result: the report now reflects the intended AgentOS identity while staying readable as a professional advisory brief. The app-side design-system bridge is also documented as part of the audit record.



Checkpoint Plan With Subtasks

0

Stabilize CI and Artifacts

0-7 days

- Fix parallel Discord test flake or configure deterministic serialization.
- Make e2e blocking after route smoke is green.
- Repair Next dev/prod artifact hygiene and use one authoritative command-center port.
- Exit: typecheck, build, default test, discord:test, e2e all green.

1

Lock Security Doors

1-2 weeks

- Add Fastify auth preHandler for mutating, worker, Discord admin, event, and scraper routes.
- Add SSRF guard for loopback, link-local, private CIDRs, file/data schemes, and redirects.
- Restrict CORS, shorten sessions, add rate limits, and minimize child process env.
- Exit: route-class auth and scraper SSRF tests passing.

2

Make UI Truthful and Reliable

2-3 weeks

- Remove or relabel synthetic LIVE widgets.
- Add stale-while-revalidate route state instead of full offline collapse.
- Add route sweep for /, /missions, /control-gate, /settings, /blackbox.
- Reduce dashboard payload from 522 KB toward less than 150 KB.
- Exit: Playwright 8/8 and dashboard p95 under 150 ms local.

3

Harden Persistence

3-5 weeks

- Adopt real migrations and one schema source.
- Enable foreign keys and indexes for missions, logs, audit, chat, approvals.
- Move hot writes off load-all/delete-all/reinsert-all mutation paths.
- Add retention/pruning for audit/log/message growth.
- Exit: concurrent run test shows no clobbering.

4

Make Agents Real

5-8 weeks

- Wire `routeLlmCall` into `packages/agents/src/llm.ts`.
- Move agent pipeline into a non-mock path; keep mock as a test double.
- Emit real token/cost usage events on mission completion.
- Exit: Ollama-backed mission produces real model output, diff, non-zero tokens, and budget evidence.

5

Sandbox and Tool Expansion

8-10 weeks

- Replace alias-only shell with constrained sandbox/container.
- Broaden tools behind policy, approvals, and audit.
- Add approval-required-for-write tests and sandbox escape tests.
- Exit: human-approved repo edit runs safely end-to-end.

6

Observe and Host

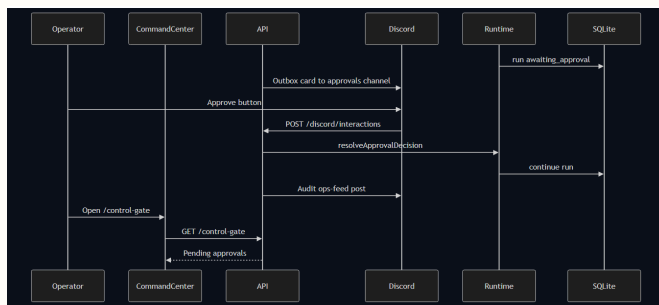
10-14 weeks

- Add metrics endpoint for latency, queue depth, run outcomes, token/cost.
- Stream logs via SSE/WS instead of polling.
- Containerize stack, parameterize host paths, repair flous.dev HTTP 500.
- Exit: fresh machine deploy reaches health and core UI routes.

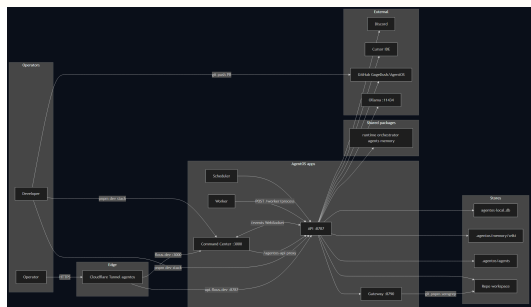
Included from `docs/diagrams/rendered`. The folder contains eight rendered Mermaid diagrams, each as SVG and PNG, generated at 2026-06-16T15:19:20.573Z.



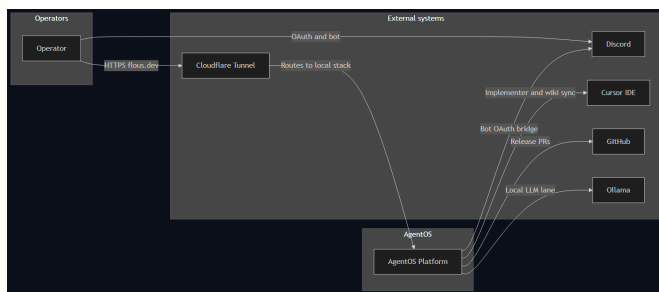
Agent pipeline



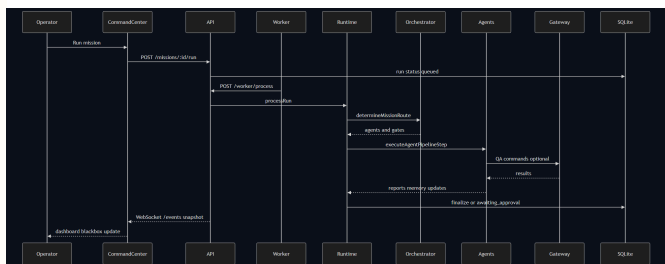
Approval gate sequence



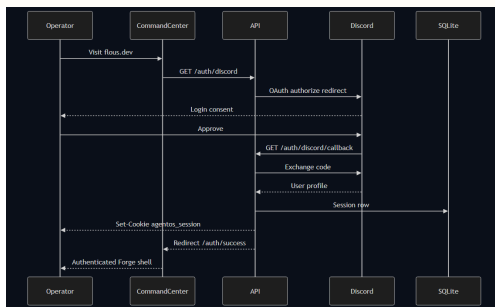
Containers



Context



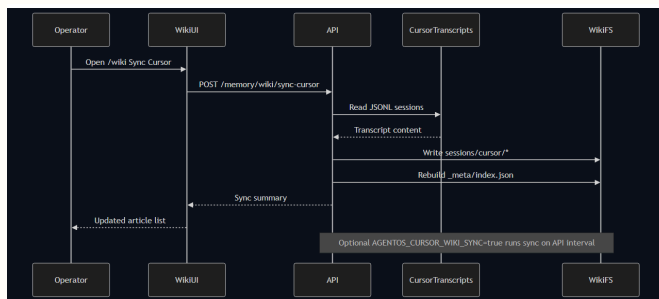
Mission run sequence



OAuth sequence



UI routes



Wiki sync sequence



Advisory Brief Close

Recommended Immediate Next Step

Do not broaden feature scope first. Establish a trustworthy operating baseline: route authZ, SSRF guard, deterministic tests, and green command-center route smoke. That gives every later agent-runtime improvement a safer foundation.

Recommended Positioning

Use "local-first AI agent command center" and "agent operations control plane." Avoid "production autonomous platform" until the runtime path proves real model output, real edits, real token/cost accounting, and real sandbox enforcement.

Go/no-go guidance: AgentOS is ready for focused local development and controlled demos. It is not ready for exposed hosted use or unsupervised autonomous repo work until the P0/P1 issues in this brief are closed.

EVIDENCE TYPE	LOCATION
Updated brief	output/pdf/AgentOS-Final-Audit-Advisory-Brief.pdf
Report source	output/pdf/AgentOS-Final-Audit-Advisory-Brief.html
Design-system bridge	apps/command-center/src/styles/forge-ds/tokens/forge-compatible.css
Visual preview evidence	output/playwright/agentos-forge-design-preview.png